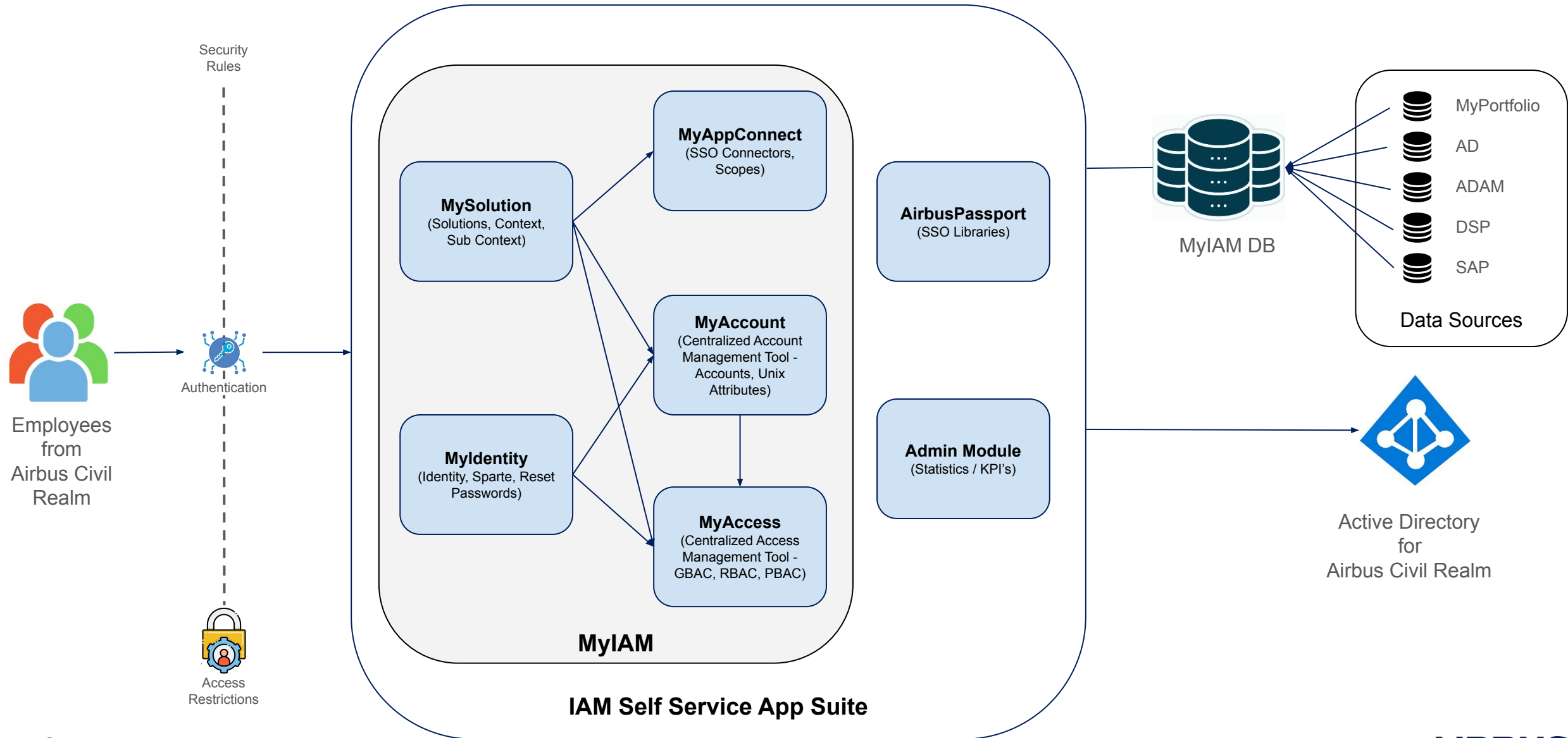


MyIAM To Be Solution Architectural Proposal

MyIAM View

Airbus Amber



List of areas to explore while designing the To Be Architecture

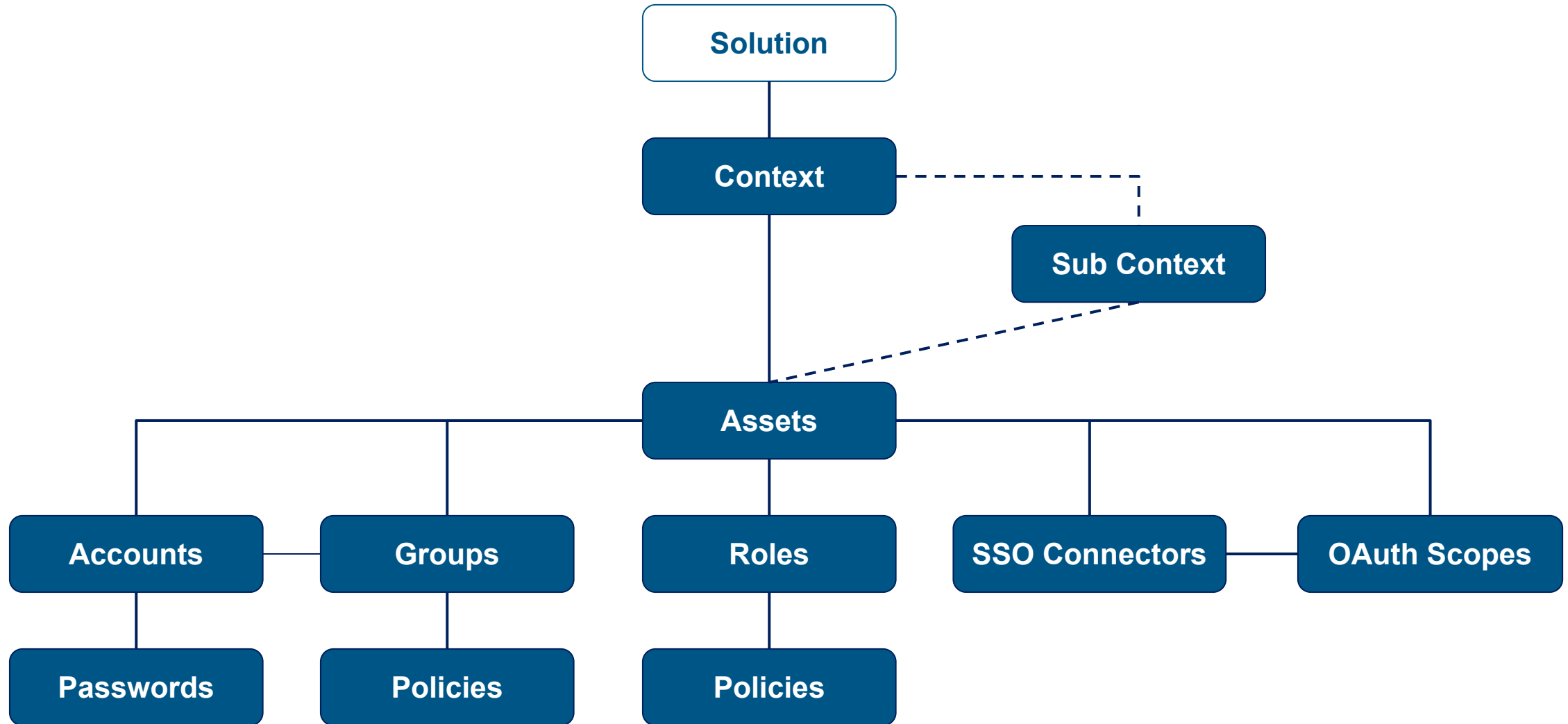
Objects that are part of the new data model:

- Solutions
- Contexts / Sub-Contexts
- Accounts
- Groups
 - Policies / Rules
- Roles
 - Policies / Rules
- Devices
 - Desktop computers, laptops, tablets, and servers
- Networks / Zones like SNS, DMZ, Domains etc.,
- Delegation Model
 - Roles for MyX Services

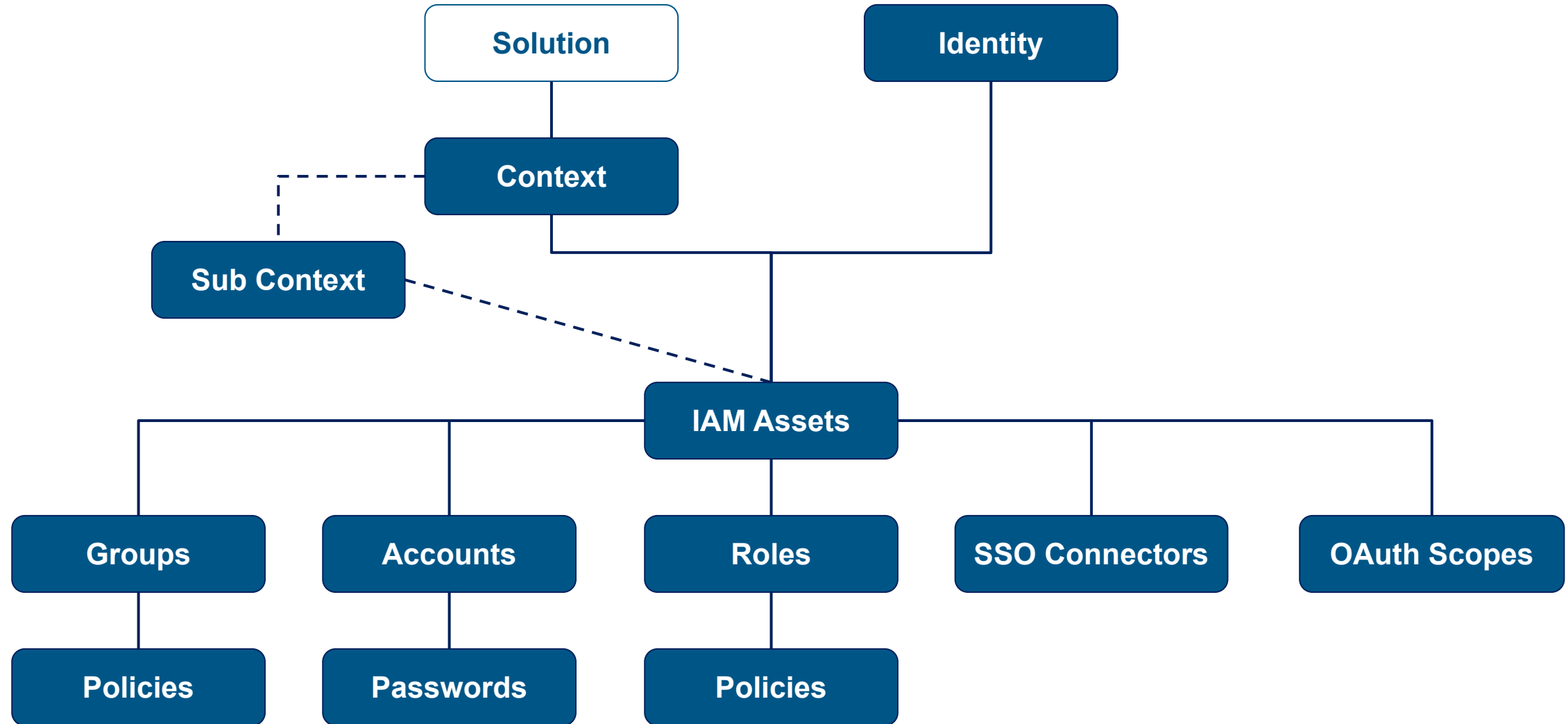
Other objects/features to take into account:

- Cockpit
- Admin Console
 - Statistics / KPI's
- Fine Grained Access Management
- User Guide
- User Journey based on the roles / personas
- AI Ops

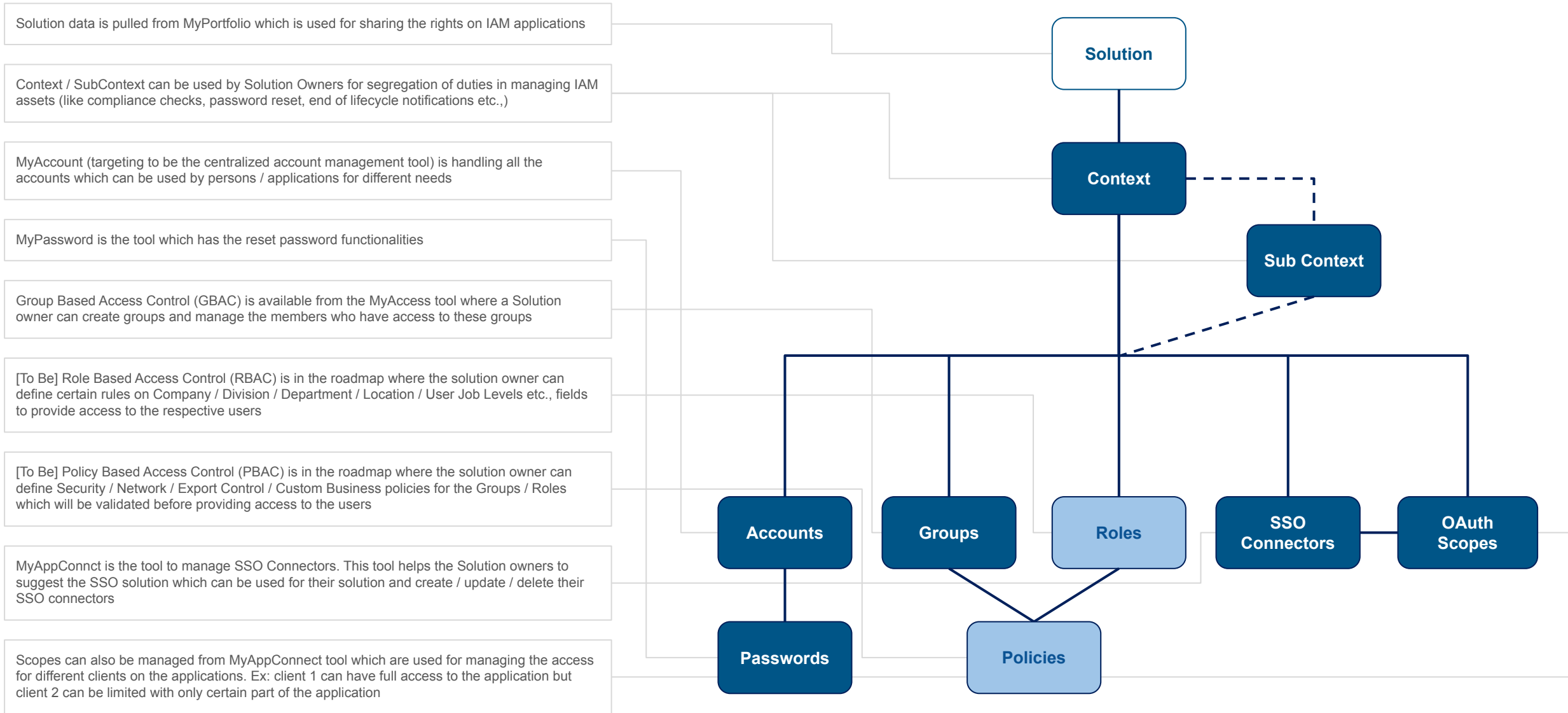
High-level Data Model



[Draft] High-level Data Model



High-level Data Model



Shareable Assets

Shared assets feature is already implemented for OAuth2 scopes in MyAppConnect application. Reuse the principle and adapt it for other relevant assets

SCO_1Z72_AD-READ  Delete  Mark Private

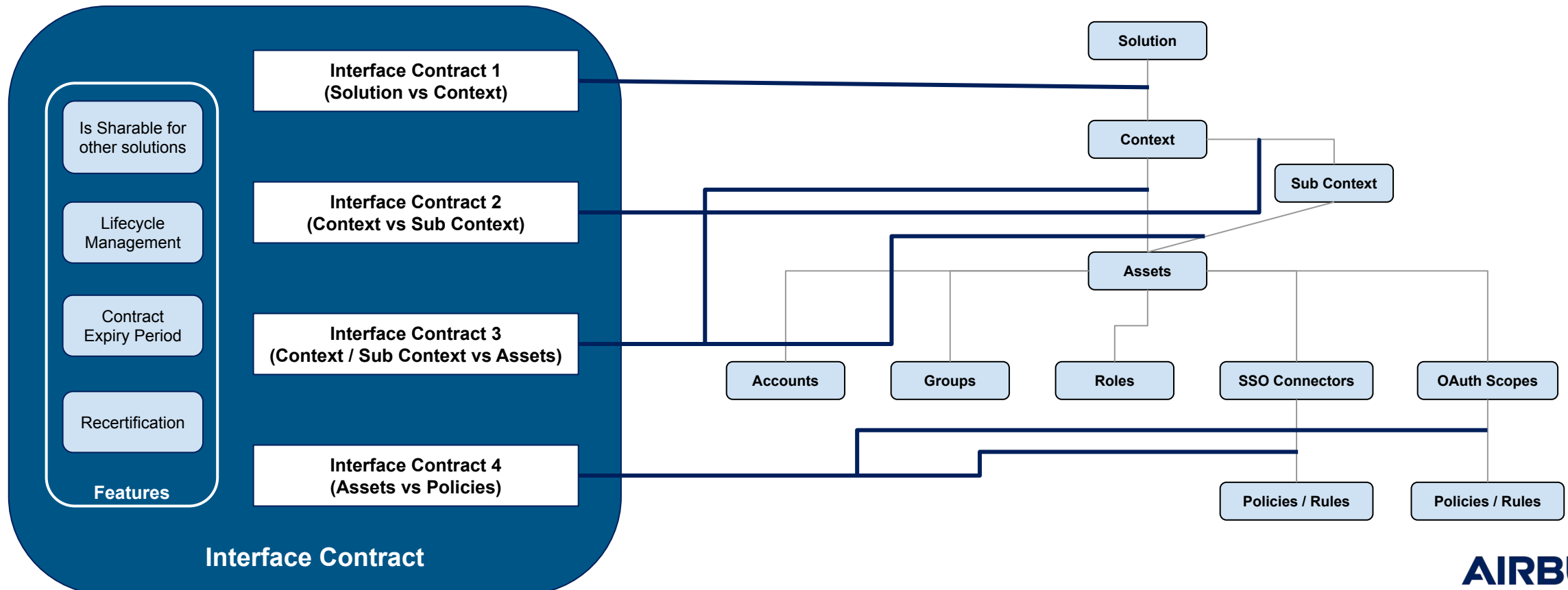
- Shared Assets is the principle used to allow other Application Owners / Delegates to request access for the particular assets through an Interface Contract
- While Creating / Updating of the respective assets, Application Owners / Delegates can have a flag to make it as Private or Sharable. By default “Private” will be enabled until the flag is changed
- Assets inside the respective solution can be accessed in Private mode as well but an Interface Contract is need if its under a different Context
- Access can only be requested via Interface Contract for those Assets marked as “Shareable”
- Request for an Shared Asset can be done using an Instant Mail and for the lifecycle management for the Interface Contract can be done using an Consolidated Mail
- Shareable Assets
 - Accounts, Groups, Roles, OAuth Scopes
- Non Shareable Assets
 - Context, Sub Context, SSO Connectors, Policies / Rules

Shareable Assets (To Be Discussed in future)

- Application Owners / Delegates can make the assets from Private to Sharable anytime but while making from Sharable to Private there should not be any active Interface Contracts linked to the asset
- Or
- Application Owners / Delegates can make the assets from Private to Sharable or Shareable to Private anytime but a mail notification should be trigger along with a warning and confirmation checkbox in UI before submitting this action
- Similar with the delete asset feature, Application Owners / Delegates cannot delete any feature if any active Interface Contracts exists for the respective asset
-

Interface contract

- Interface Contract is to access assets from other solutions
- Interface Contract will be integrated for all the relevant levels in the data model (like solutions, contexts, sub-contexts and assets)
- Interface Contract should extend its capabilities to include the lifecycle management (with the expiration date, recertification process, etc.)

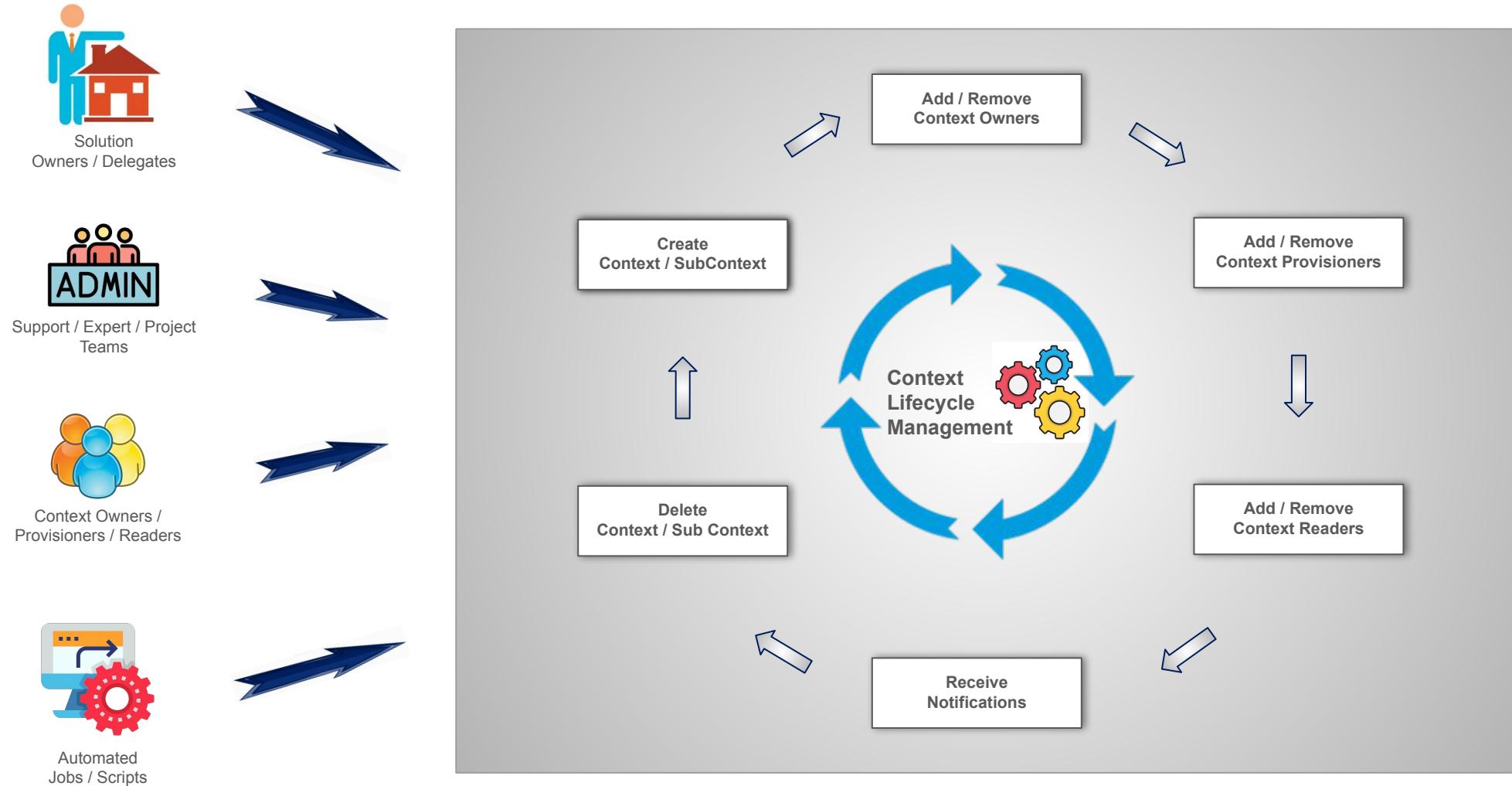




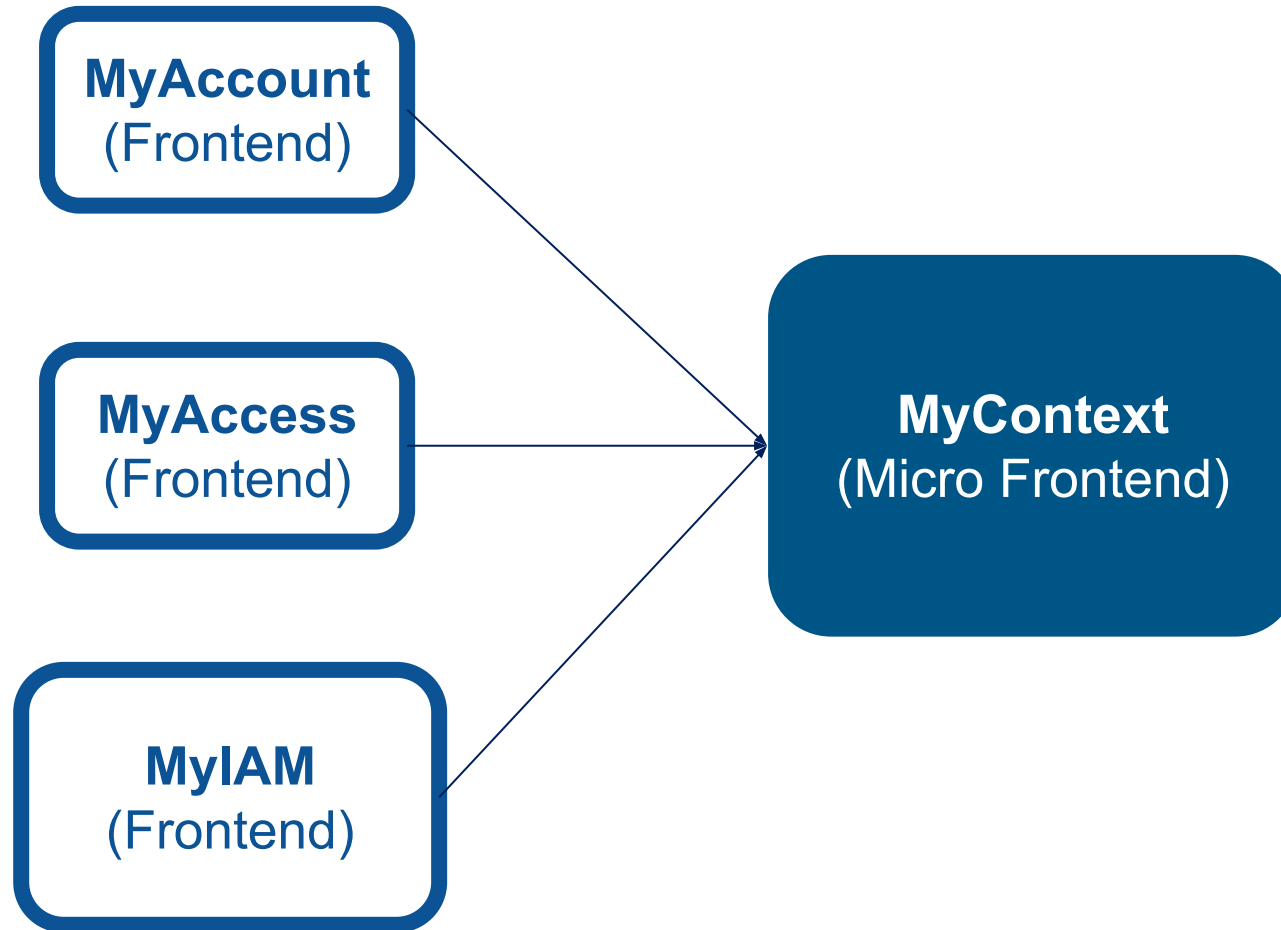
Context & Sub Context Management

- ❑ MyContext Micro Frontend
- ❑ Sub-Context
- ❑ Sub-Context Delegation Rights

Context / SubContext Lifecycle Management



MyContext Micro Frontend



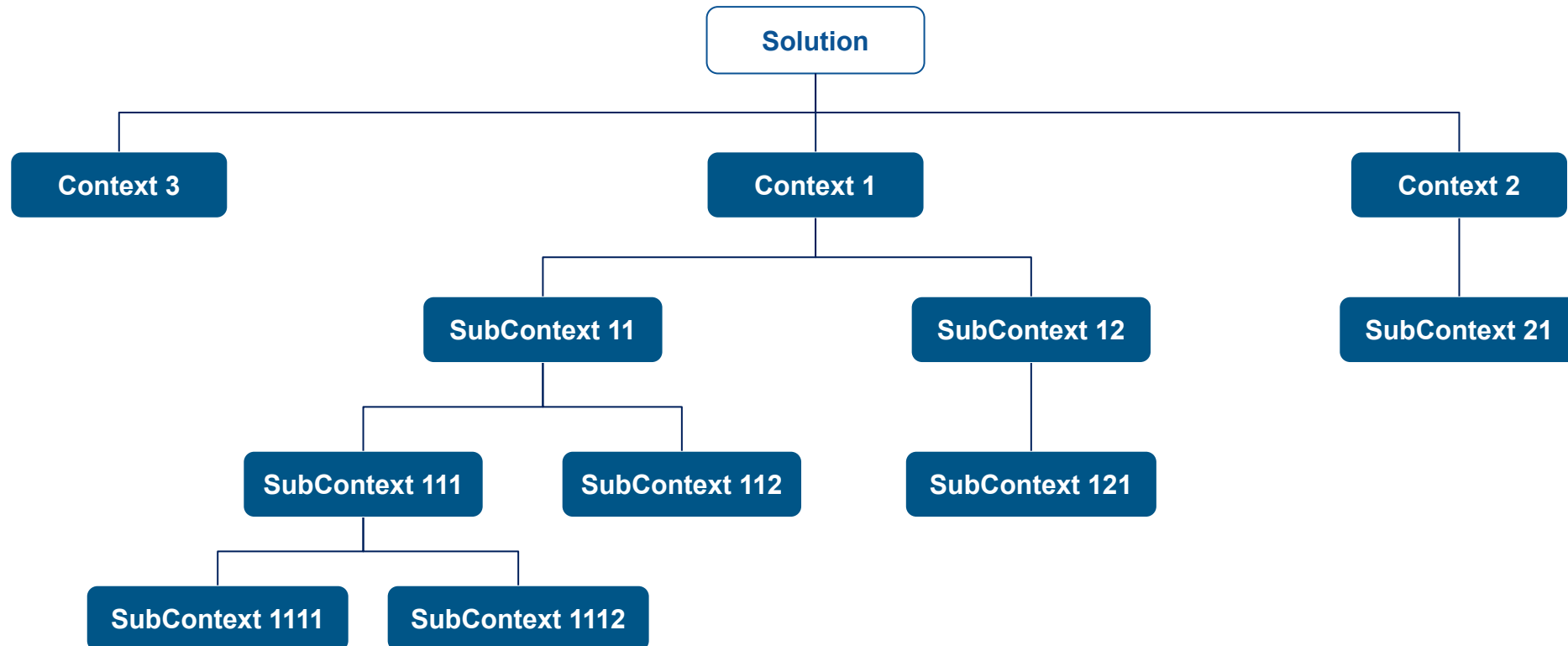
- MyContext will continued to be developed as Micro Frontend
- The same MyContext module will be integrated by MyAccess as well as MyAccount and it will be prepared to be integrated in MyIAM

Things yet to explore in Micro Frontend approach:

- Inherit styling / theme from parent application
- Create pipelines to deploy Micro Frontends independently on Dev / Val environments and deploy the code together on Val / Preprod / Prod environments
- Redirections to same route can happen from many places. Back button should take the user back to the expected screen
- Consistency in Development standards like state

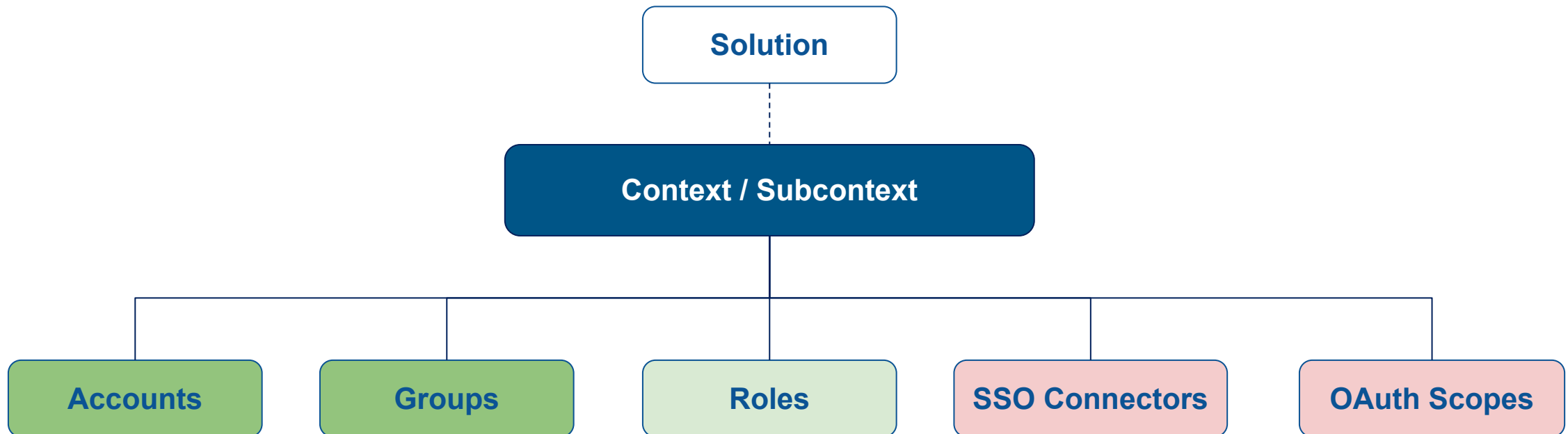
Sub-Context

- A Sub Context can have one or more Sub Contexts linked to it
- Sub Context Alias field can be removed
- All IAM Assets should be having optional attribute - Context / Sub Context in MyX Database
- Nomenclature of Assets is only expected to have Solution Code but not Sub Context name in it



Sub-Context Delegation Rights

- While creating / updating Sub Context, Application Owner / Delegates should be provided with option to inherit delegation rights from parent or not
- In case the delegation rights are not inherited from parent, some of the users should be mandatorily added as delegates
- Check if multiple toggles can be implemented for mails like passwords etc., on inheritance rights
- While deletion of Sub Context, Application Owner / Delegates should be provided with option to tag these Sub Context assets to some other Sub Context or at parent level
- Notifications for Application Owner / Delegates should also be send only if the parent delegations are enabled
- Delegation model of the Context / Sub Contexts should be handled by MyX applications instead of relying on AD



Anubis

- ❏ List of potential features to implement



Anubis integration with MyAccount

- Create Accounts
 - Radio button to enable / disable “Unix Attributes”
 - If Unix Attributes are enabled a specific fields for “Auto Home” etc., fields can be asked for the end users
- Update Accounts
 - Edit button to enable Unix Attributes and provide the specific data can be provided
- End User accounts (logon accounts) can also have the unix attributes
- Migration of all the data from Anubis to MyAccount

MyAppConnect

- ❑ List of potential features to implement
- ❑

List of potential features to implement

- Should we segregate scopes based on versions?

- ❑ List of potential features to implement
- ❑ Forgot Password feature
- ❑ Forgot Password feature detailed representation
- ❑ Forgot Password feature detailed steps
- ❑ Forgot Password feature prerequisites
- ❑ Forgot Password API's Security Protection

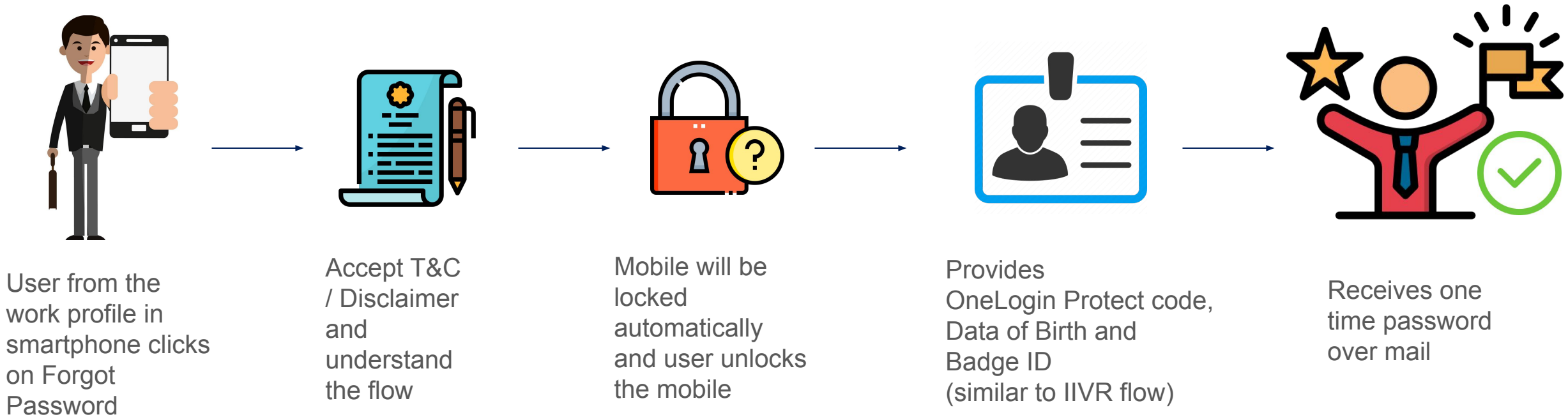
Airbus Passport Mobile App

List of potential features to implement

- Integrate Forgot Password and Buddy Reset Password functionalities powered by MyPassword backend
 - Forgot Password Flowchart: [click here](#)
- Authorize different authentication authorities from Airbus Passport (Current design - only Onelogin / Mobile SSO deployed in Android and IOS). Below are some list
 - Corp SSO - SAML Protocol - ID Fed is the boker
 - Mobile SSO - OIDC / OAuth
 - Onelogin
 - DMZ - SP Broker
 - Siteminder (Reverse Proxy) - ADAM DMZ credentials are used for legacy needs when it acts as IDP
- Adapt to multiple MFA strategy
 - Service Delivery Kit (SDK) can be integrated with Airbus Passport
- Name, Universal Logon, Mail etc., professional identity details can be provided to other systems
- Notification, Community etc., services to have some common components available for all the mobile apps

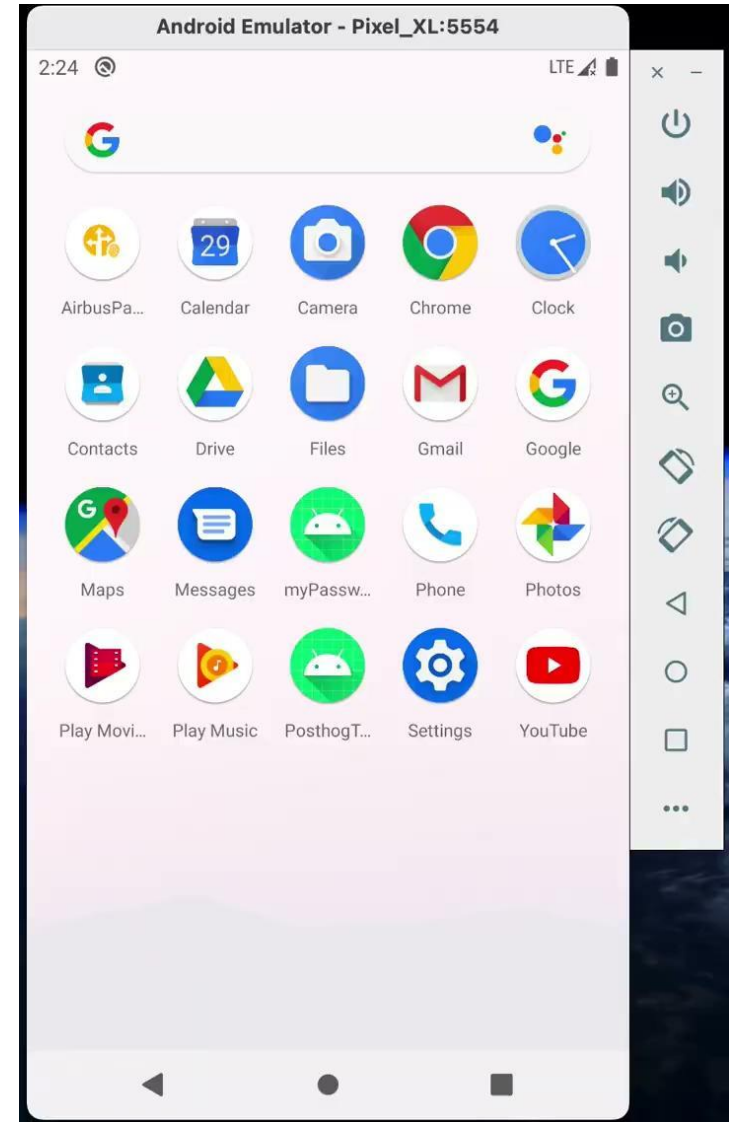
Forgot Password feature in Mobile App leveraging IIVR flow

- As we have our mobile apps in the Airbus Private cloud and the user can access them only after creating the work profile, the proposal is if we can consider this as a secured device and enable the forgot password / password reset feature with an MFA
- Validate users information like Mobile Screen Lock, Badge ID, Date of Birth and OneLogin Protect code after accepting Terms & Conditions
- After the validations are successful, the password reset can be done and the onetime password will be sent to the User's Email



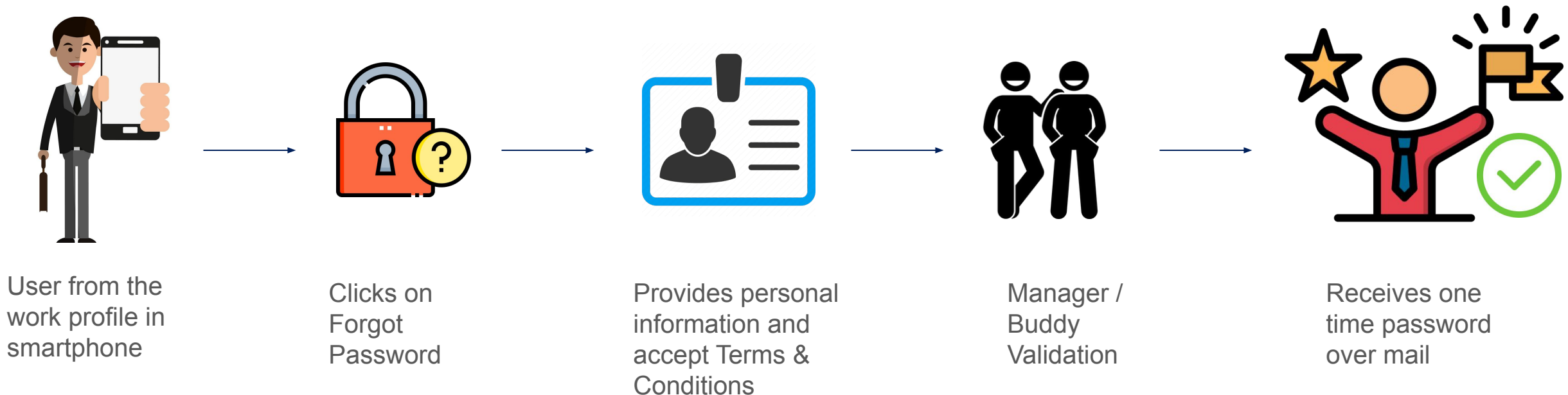
Forgot Password Implementation

- An existing solution IIVR is not easy to enable for different countries due to IVR (Interactive Voice Response) process. So proposing to release the similar flow from Mobile Interface
- Security
 - Feature will be available from users workprofile and the app can be downloaded only from Airbus Private Cloud
 - User should accept the terms and conditions
 - Before accessing forgot password feature users mobile will get locked and user needs to unlock the mobile
 - User enters the Badge ID and Date of Birth
 - User needs to provide OneLogin Protect code
 - Also the temporary password will be sent to User's Mail
- Integrating with Airbus Password as its an existing Mobile App and also handles the Login feature
- Flow Diagrams: [click here](#)



Forgot Password feature - old proposal

- As we have our mobile apps in the Airbus Private cloud and the user can access them only after creating the work profile, the proposal is if we can consider this as a secured device and enable the forgot password / password reset feature with an MFA
- Validate users personal information like Screen Lock, Validate User's Sensitive Information (like Badge Details, Date of Birth etc.), Accept Terms & Conditions
- Manager's validation to approve the request and provide the onelogin protect code
- After the MFA, the password reset can be done and the onetime password will be sent to the User's Email

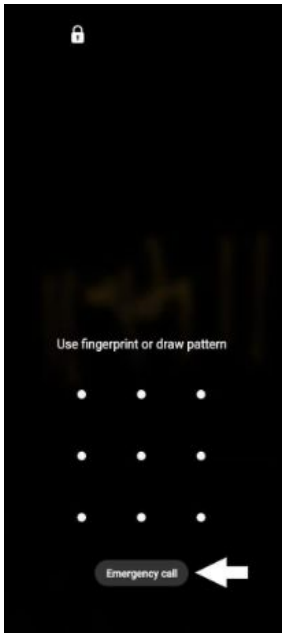


Forgot Password feature detailed representation

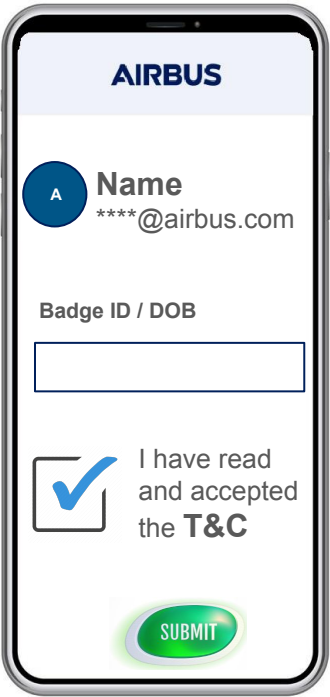
Airbus Amber



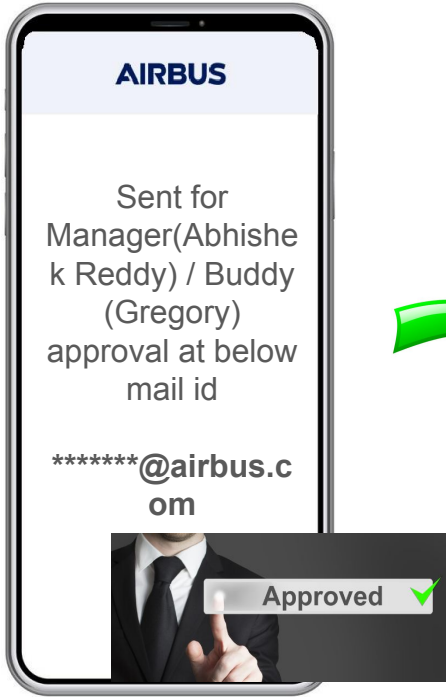
When user clicks on forgot password



Mobile screen will be locked where the user needs to unlock the screen



Accept T&C and provide sensitive / personal information linked to email for validation



Manager / Buddy validation from Onelogin Protect app



User receives one time password over mail which has to be updated at the time of first login



Forgot Password feature detailed steps

- The first screen of MyPassword mobile app contains a screen to access “Forgot Password” feature or access the other “MyPassword” features providing the user's credentials
- Forgot Password will be by default enabled for everyone irrespective of the role. But users can reset password only for their account for which the work profile is created
- **[MFA-1]** Once the user clicks on forgot password, the mobile screen will be locked where the user needs to enter the password / fingerprint etc., to unlock the screen
- **[MFA-2]** If the user unlocks screen successful, he/she will be shown with the basic details of his/her profile like email id (details will be extracted from the work profile) where the user should provide their personal information like “Date of Birth”, “Badge Details” etc., linked to the displayed email id and also accept the Terms & Conditions
- **[MFA-3]** Now the user can select one of their buddies / manager to provide the approval. Once user selects the email id from dropdown, he/she will be waiting for an approval from their respective manager / buddy for x secs. Where the respective manager / buddy can approve the request from their “Onelogin Protect” app on their mobile
- After the manager / buddy approval, a success message will be shown to the user that he/she received an one time password over mail
- Once the user uses this password to login, a request to update their password will be popped up similar to the buddy reset feature
- User can click on cancel at any of the step where the user will be redirected to home screen

Forgot Password feature prerequisites

Below are some of the prerequisites to access the forgot password feature in mobile:

- User should have the work profile created on his/her smartphone
- Gmail should be installed
- MyPassword Mobile Application should be installed
- Buddy / Manager validation is one step in the MFA, so they should be available when user wants to access this feature
- Setup specific authentication mechanism (if required)

Forgot Password API's Security Protection

- Mutual TLS between the users work profile and the Gateway
- For each MFA step, a validation will be taken care to confirm the previous MFA steps are passed in the last few minutes
- Specific Authentication Mechanism - U2M token with the long lifetime
 - We shall create a dedicated client id and scope for which the ID token will be having a long lifetime and access token will be refreshed for every few mins. This helps us to reduce the risk and ensure the security standards
 - This mechanism can be integrated with the work profile setup
- The IP address from which the user is accessing the forgot password feature will be validated against the user's respective work profile configurations
- Any 2 invalid entries submitted for an MFA will lock the account and user will be displayed a message to contact System Administrator for unlocking the account (to be validated)
-

Forgot Password API's Security Protection

➤ Specific Authentication Mechanism

- U2M token with the long lifetime (preferred approach)
 - We shall create a dedicated client id and scope for which the ID token will be having a long lifetime and access token will be refreshed for every few mins. This helps us to reduce the risk and ensure the security standards
 - This mechanism can be integrated with the work profile setup

OR
- M2M token with IP address check
 - We shall create a dedicated client id and scope which can be accessed by an M2M token
 - The IP address from which the user is accessing the forgot password feature will be validated against the user's respective work profile configurations

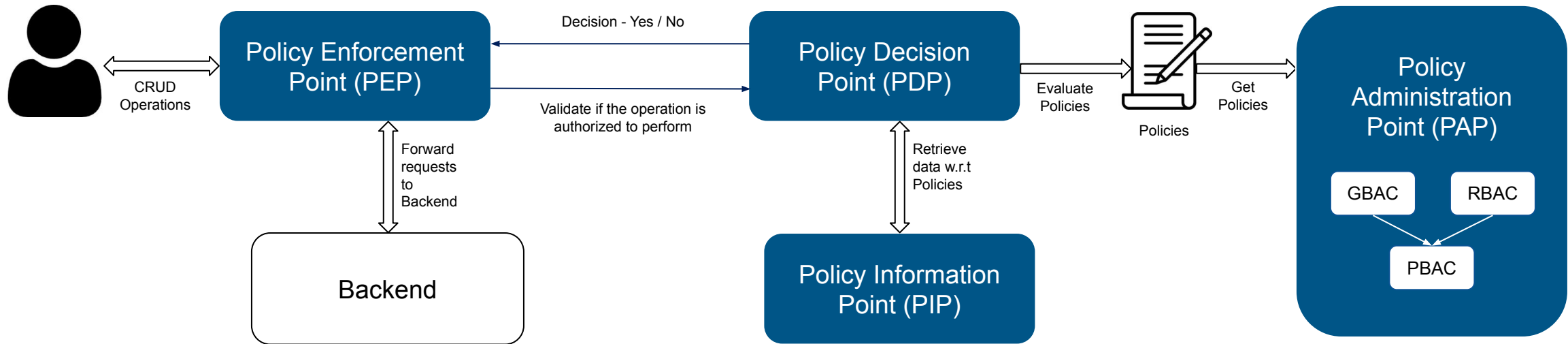
OR
- U2M token with the long lifetime (preferred approach)
 - We shall create a dedicated client id and scope for which the ID token will be having a long lifetime and access token will be refreshed for every few mins. This helps us to reduce the risk and ensure the security standards
 - The IP address from which the user is accessing the forgot password feature will be validated against the user's respective work profile configurations



- ❑ PEP vs PDP vs PAP vs PIP
- ❑ RBAC vs ABAC vs PBAC vs ReBAC
- ❑ GBAC (Group Based Access Control)
- ❑ RBAC (Role Based Access Control)
- ❑ PBAC (Policy Based Access Control)
- ❑ Central PAP (Policy Administration Point)
- ❑ PIP
- ❑ PDP
- ❑ Recertification for all Authorization layers handled by MyAccess

MyAccess

PEP vs PDP vs PAP vs PIP



➤ Policy Enforcement Point (PEP)

- PEP is responsible for receiving authorization requests that are sent to the PDP for evaluation. Ex: IAM Gateway

➤ Policy Decision Point (PDP)

- PDP takes the request from the PEP and applies a set of policies to the request to determine the action is permitted or denied

➤ Policy Administration Point (PAP)

- PAP is responsible to provide policies to the PDP. Ex: IAM Endpoint Protection

➤ Policy Information Point (PIP)

- PIP shares the information required for the policy to execute. Ex: GBAC

RBAC vs ABAC vs PBAC vs ReBAC

➤ **Role-Based Access Control (RBAC)**

- RBAC grants access based on user roles considering attributes like user company, user division, user department, user designation / job role etc.,
- User Roles created using RBAC can have the periodic data refresh and the dedicated storage instead of dynamic computations. This can be the as is replacement from GBAC to RBAC.

➤ **Attribute-Based Access Control (ABAC)**

- ABAC grants access based on the attributes of the user, resource, and environment.
- It can be considered as a combination of RBAC and PBAC under one component.

➤ **Policy-Based Access Control (PBAC)**

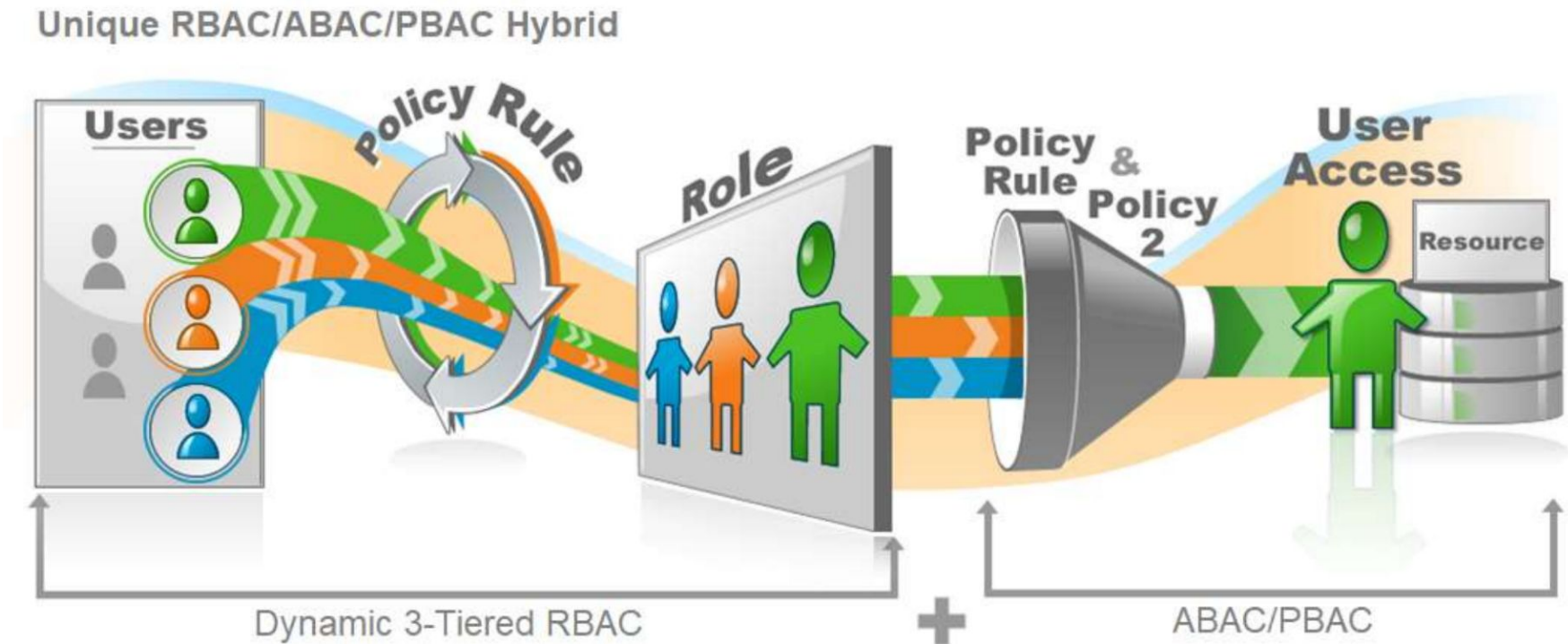
- PBAC grants access based on policies that are dynamically managed / contextual in nature like user roles vs job functions, geo location, network location LAN / DMZ / Internet, time at which the resources are accessed, compliance checks, user nationality etc.,
- PBAC can be extended to specify exactly what actions a user / role can perform on each resource. Ex: Admin could allow a user to read and write files, but not delete them

➤ **Relationship-Based Access Control (ReBAC)**

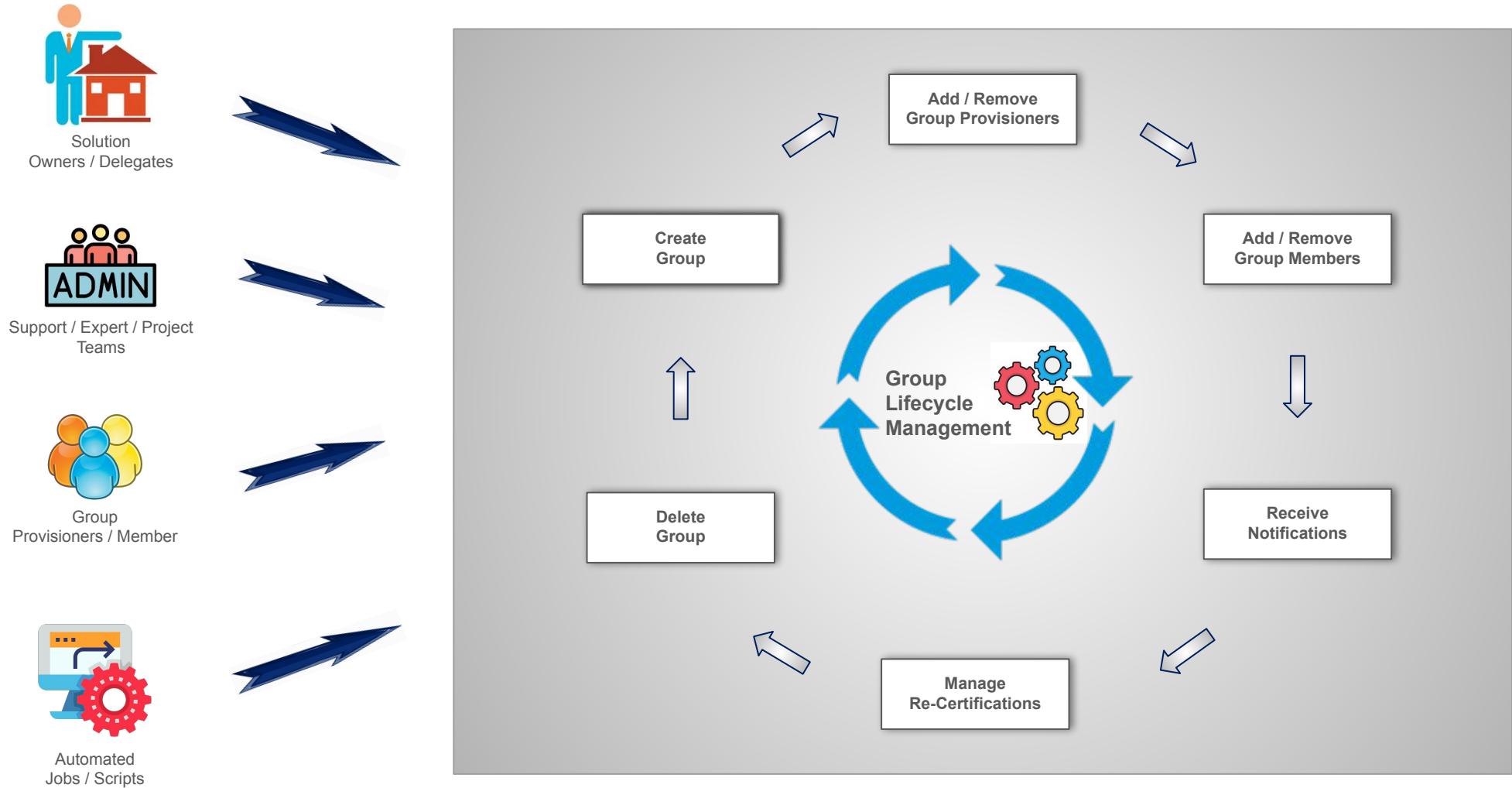
- ReBAC grants access based on the relationships between users and resources.
- Apart from the checks provided by RBAC / ABAC / PBAC components, ReBAC can be used to link permissions to resources. Ex: Admin could allow a user (could be RBAC / ABAC / PBAC policy) to read and write files, but not delete them (actions on resources)

Policy Management (RBAC vs ABAC vs PBAC vs ReBAC)

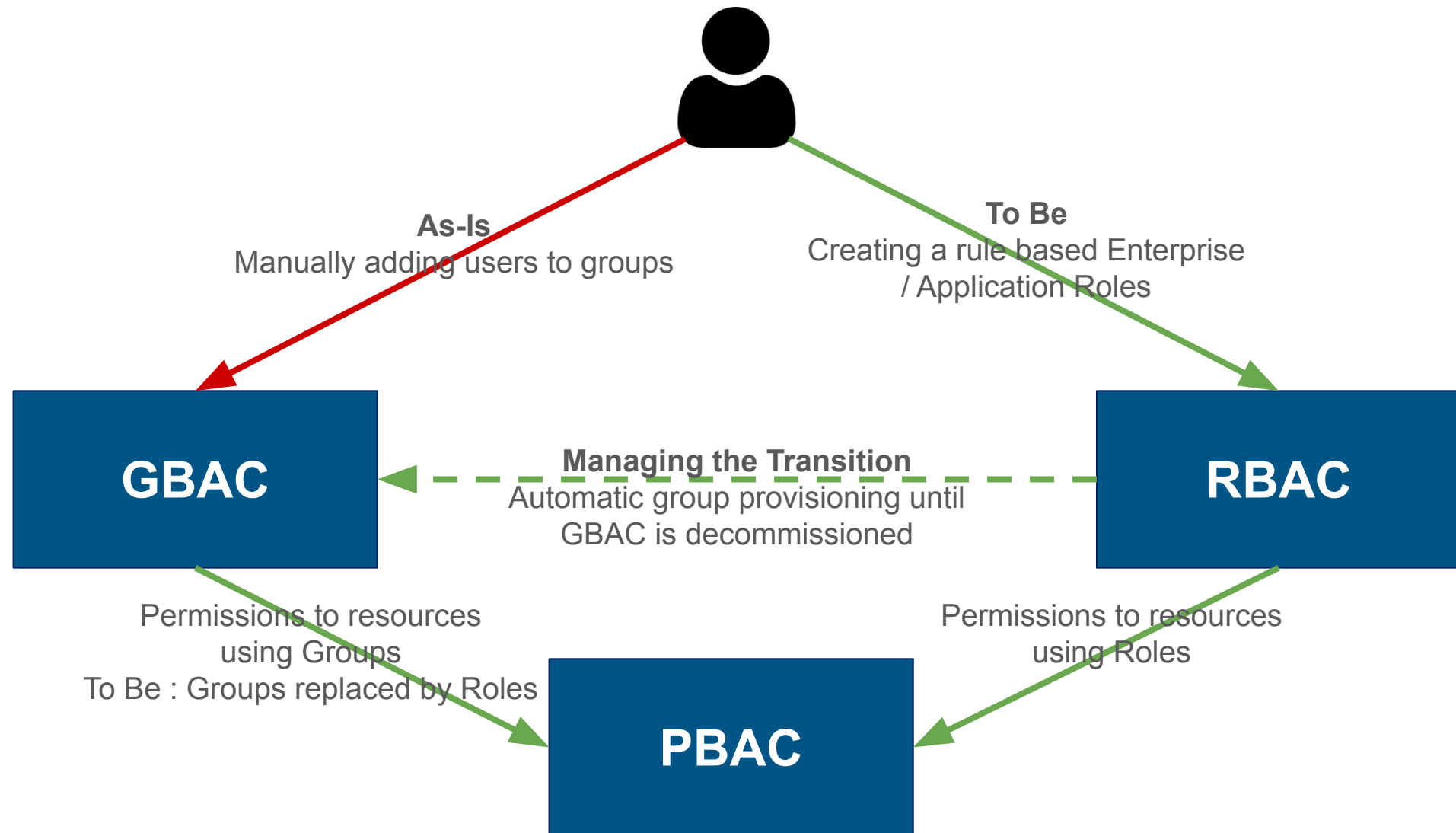
User / Role	Runtime Checks	Permission / Operation	Resources / Applications
Airbus	Compliant, LAN	End User / Login	Onelogin, G-Suite, Netscope, Nomad, MyPortfolio
Airbus, Commercial Aircrafts	Compliant, LAN, Working Hours	End User	MyIAM, Airbus Passport, other Self Service apps, specific GDrive folders
Airbus, Commercial Aircrafts , Dlgital, DIA, Architects / Experts	Compliant, LAN, Working Hours	Admin	Onelogin, AD, ADAM, specific GDrive folders



GBAC (Group Based Access Control)



Transition from GBAC to RBAC



RBAC (Role Based Access Control)

- Business / Application Roles are created using RBAC of MyAccess. Below is the explanation of how the Business / Application Roles are linked to the Enterprise Roles
 - Enterprise Roles
 - This is defined by the details of the person based on the audience, division, department, siglum etc.,
 - Business / Application Roles
 - This is the rules defined by applications to provide access for the specific Enterprise roles
- Since the Users linked to these Roles are dynamically assigned, the data will be refreshed periodically
- Static Rules can be based on the below attributes. Multi selection on different categories of rules will define a Role
 - Company - Airbus, ATR, Capgemini, Air France, Not Airbus
 - Divisions - ACA, AH, ADS
 - User Type (Audience) - Employee, Supplier, Customer
 - Departments / Siglums
 - User Company Location
 - Designations / Job Levels / Job Titles
 - Roles can be internal to the same solution
 - Add / Remove Members (using Universal Logon and also highlight asking for users not use this feature as its tough for recertification on their side and also not so good from security standpoint)
 - Etc., (maybe take a text from end user, so the needs can be performed manually by the support team)

RBAC (Role Based Access Control)

Enterprise Role

- Sample Enterprise Role Name Nomenclature: Company_Audience_Divisions_Department_Siglum
- It can be defined with attributes mentioned in the table.

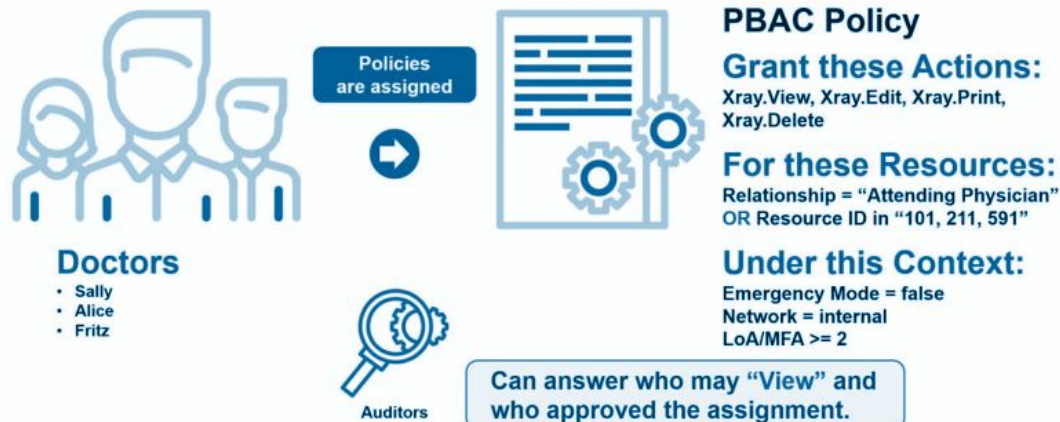
Company (Attribute 1)	Audience (Attribute 2)	Division (Attribute 3)	Department (Attribute 4)	Siglum (Attribute 5)
Airbus	Employee	Commercial Aircraft	IIDIA	IIDIAA
Capgemini	Supplier (Work Force or Non Work Force)	Airbus Helicopters	XXX	XXXX
Other	Customer	Defense & Space	XXX	XXXX

Business / Application Role

- Business / Application roles can be created on need basis which are having certain fine grain checks on top of Enterprise roles which can be based on the application needs
- Attributes like User Designation / Job Level / Role, User Nationality, User Company Location, etc., can be considered
- Data Quality on all the attributes should be validated before RBAC EIS. Aligned with respect to multiple teams like JML, HR etc.,

PBAC (Policy Based Access Control)

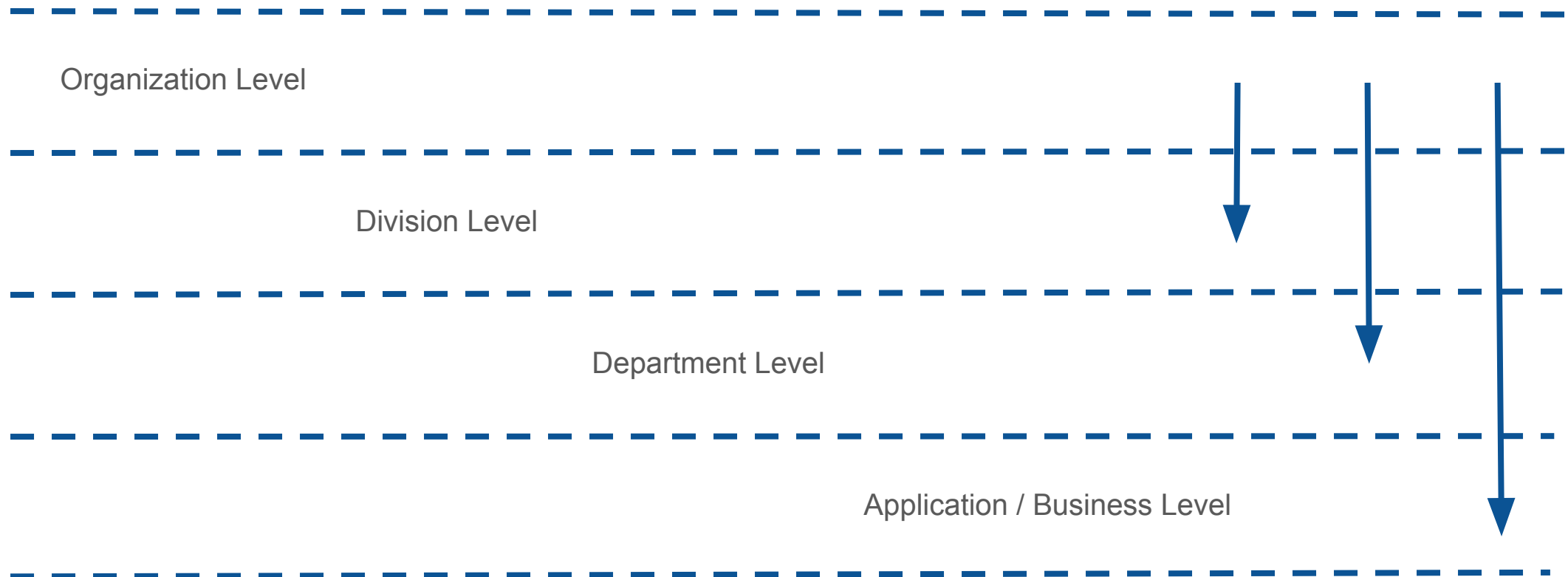
- Policies can be linked with Roles and Groups (Groups has to be rechecked)
- Policy can be tagged at different levels like below
 - Organization Policies
 - Division Policies
 - Department Level Policies
 - Individual Business Policies
- PIP / Data Sources to validate PBAC policies in PDP
 - MyAccess - RBAC / GBAC
 - AD / ADAM
 - Onelogin / SSO solution
 - Network Zone
 - etc.,



- Context / Runtime Checks
 - Security
 - Account is Compliant (ex: not expired)
 - Time at which the resources are accessed
 - Device from which the resources are accessed
 - Network
 - Access call coming from Airbus LAN or Airbus DMZ or Internet
 - Geo Location from which the resources are accessed
 - Regulations like Export Control
 - Accreditations based on User Nationality, Geo Location etc.,
 - Custom Business / Application needs
 - Endpoint Policies (similar to Endpoint Protection)
 - Custom policies can be defined like <"Attribute Name"> <"Comparison Type"> <"Attribute Name / Text Value">
 - Comparison Types can be equals, not equals, greater than etc.,

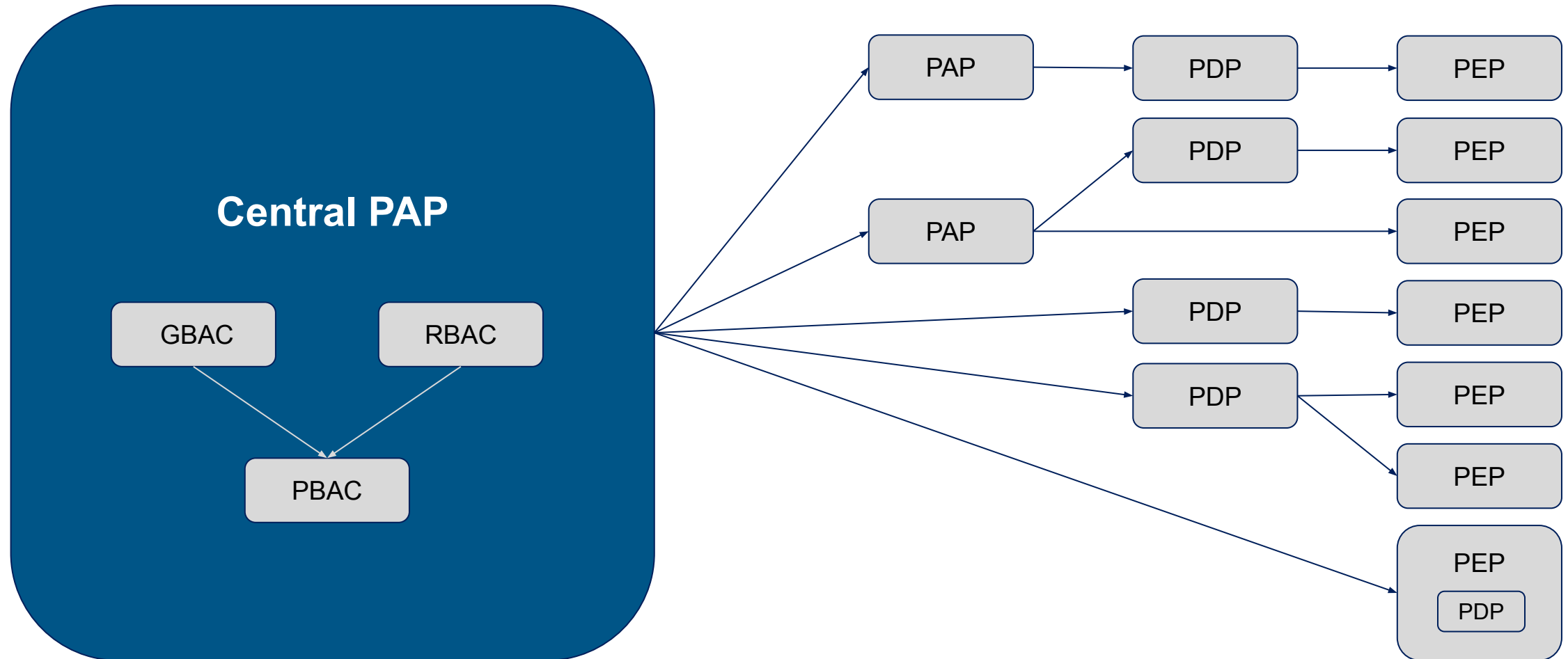
PBAC (Policy Based Access Control)

- There can be a potential hierarchy which can be found in different levels like shown below.
- So the bottom level will have the checks imposed by their parent levels.
- Mandatory & Recommended Policies at different levels.



Central PAP

With GBAC, RBAC, PBAC the plan is to transform MyAccess into the Central PAP system which connects with other Policy Administration Point (PAP) / Policy Decision Point (PDP) / Policy Enforcement Point (PEP) systems in Airbus Civil Realm



- GBAC API's (already existing)
- RBAC API's
 - GET list of enterprise roles / application roles
 - GET details of a specific role
 - GET list of role members
 - etc.,
- Things to support PDP / Rule Engine component for the Static and Dynamic / Runtime checks to be performed on User Attributes
 - Identity
 - AD
 - ADAM
 - SSO
 - Network
- Extract all RBAC / PBAC policy files from Policy Store
- Push data to OPA rule engine in JSON format and store the results to the NoSql / MongoDB

Useful Links

- Rego Policy Language: <https://www.openpolicyagent.org/docs/latest/policy-language/>
- Rego Playground: <https://play.openpolicyagent.org/>
-

- ❏ List of Account Types
- ❏ GMSA
- ❏ Workstation
- ❏ Admin

MyAccount

List of Account Types

Below are the list of Account Types which can be enabled from MyAccount:

- GMSA
- TA Workstation
- TA Admin
- TA Indus
- Secure (TA Secure, SA Secure)
- SA Bind
- Training (TA)
- Testing (TA, SA)
- RPA
- Non Human (Ex: RPA, Automation, Synthetic)
- Bastion
- Shared
- Synthetic / Cloud
- FTS
- Local (like ServiceNow, SAP etc.,)

GMSA

Deactivation accounts for GMSA

Plan the deletion of accounts for all Account Types

Define the flow when a set of accounts can be allowed to delete after “X” number of deactivation days

Complete all the test cases from MyAccount

Workstation Account Type

New Account Type:

- A new Account type called Workstation accounts will be created
- This new account type will be available only for the backbone solution
- Workstation accounts will be created in a dedicated folder “wkst” in AD for security needs

Nomenclature:

- As workstation accounts are not linked to the application code and also as per the business needs, we will be following below nomenclature for the Workstation Accounts
TA-WKST-<User ID>

Account Attributes:

- While creating the workstation accounts, Account name and domain will be prefilled based on the Users details. User cannot change these fields (can we skip domain field from creation form to simplify the flow for user?)
- Environment will be prefilled as PROD and greyed out from UI or this field can be skipped from UI (can we skip environment field from creation form to simplify the flow for user? Also do we need these accounts for other domains?)
- Justification has to be selected from the dropdown and user can enter text if no specific details from the dropdown matches their need (need to formulate the list of options which can be presented in dropdown)

Workstation Account Type

Specific Approval flow:

- First approval will be sent to the User's manager which will be extracted from ServiceNow
- Second approval will be sent to Security Team (DSFI) (can we skip approvals for users asking EoL for 1 week and make approvals for a longer period of time)

Lifecycle of Accounts:

- 30 days will be the default end of lifecycle for these accounts (can we extended this eol for any specific cases?)
- Notifications will sent for 15 days and D-1 (29) days
- Renewal / Refresh / Reactivate of these accounts will also go for approval

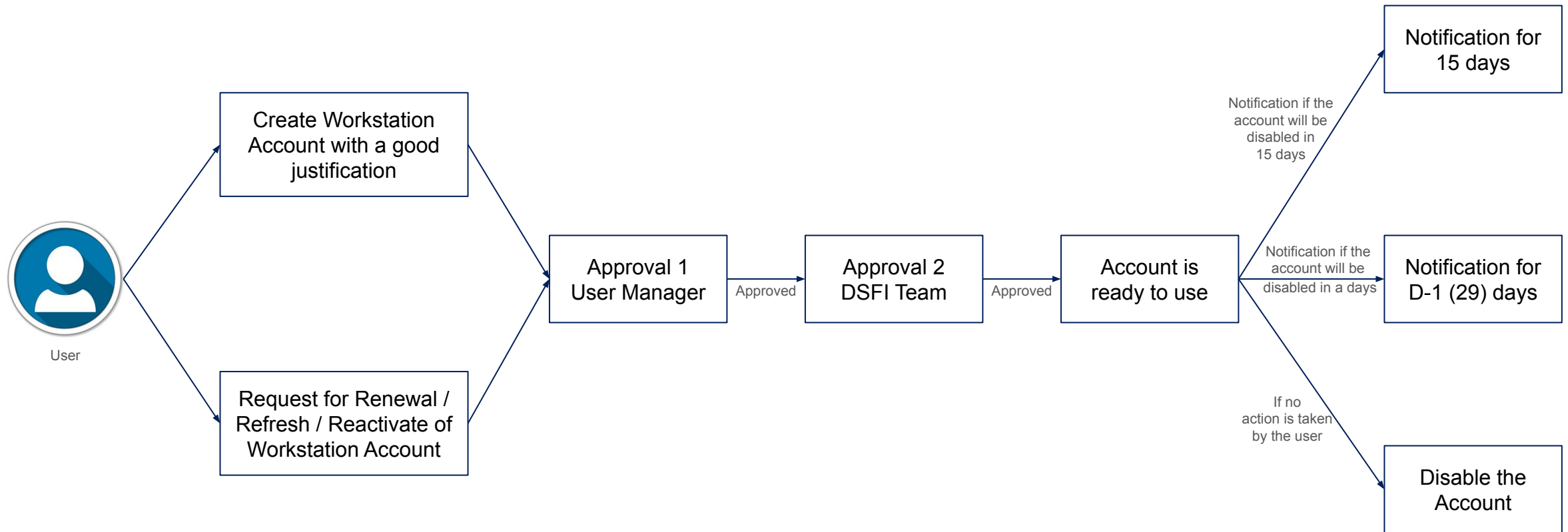
Delegation Rights:

- As these accounts are not linked to a Solution but to the end users, all the notifications / delegations will be handled by the end user themselves and the notifications will be sent to their managers

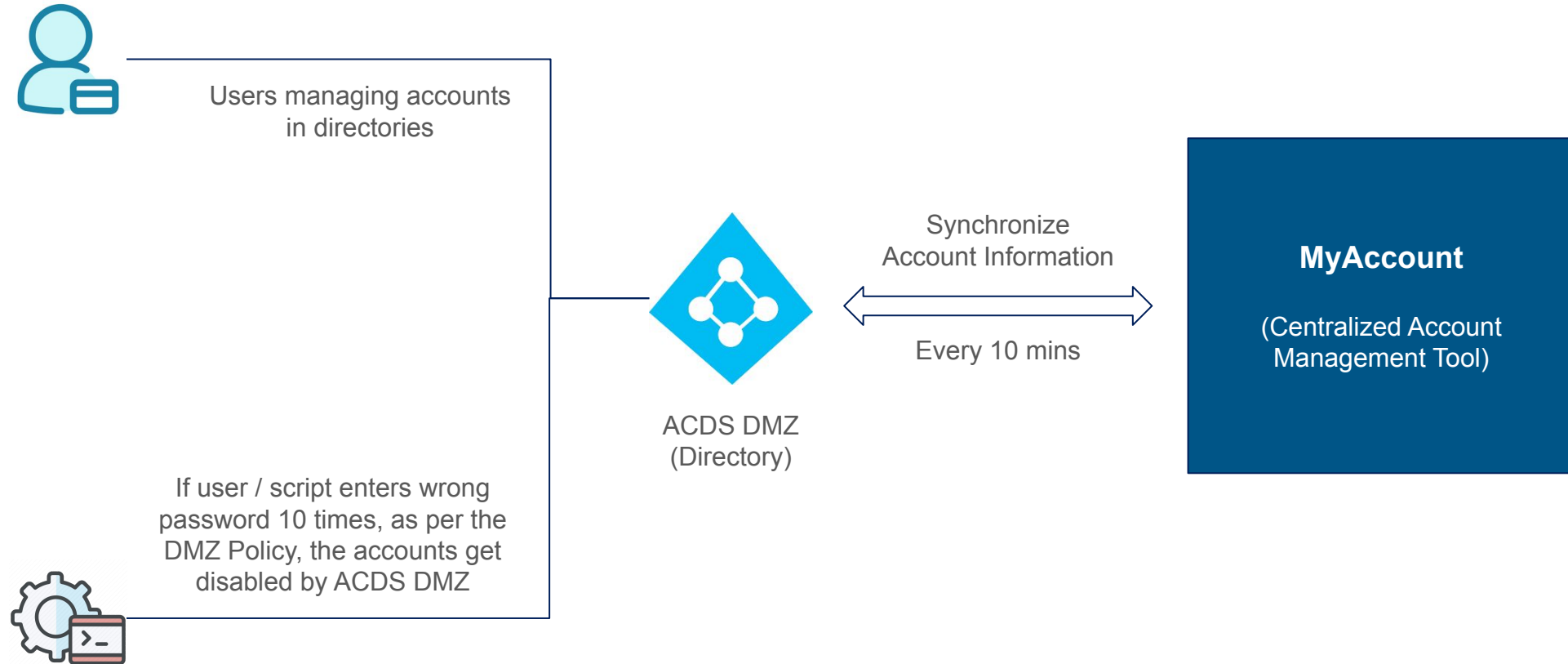
Compliance:

- Migrate to new solution and remove existing accounts and also find out cases like if these accounts are added to the groups to bypass the access rights
- DSFI to own the SLA for these accounts as the approvals will be tagged to the team

Workstation Account Type



As Is - DMZ Accounts Flow



Asset Tagging

- Introduction

Introduction

Asset tagging is the process of affixing identification tags or labels to assets.

Below is some list of Use Cases which can be using the Asset Tagging feature:

- Solution to Policy Hierarchy tagging
- Group Tagging for Export Control
- Segregating Responsibilities

Below are some of the tagging categories:

- Export Control accreditations
- Enterprise Assets
- Infrastructure Assets
- Assets with Privileged Access (PAM)
- VIP Assets

Some of this are already segregated as types of assets but we can analyse if tags can also be utilized for this categories.

Analysys needed to check how to apply below principles based on tags:

- Dashboarding
- Get Endpoints
- Delegations
- Notifications
- Restrictions

Delegation Model

- ❑ List of potential features to implement
- ❑

Delegation Model

- Solution Owner and Solution Delegate from MyPortfolio will be considered as the Primary Owners for any solution
- Solution Architect role from MyPortfolio should also have some rights on the application, may be similar to Solution Delegates
- <https://docs.google.com/spreadsheets/d/1TVwvDEZsNizUXNCLma6Pb2rFHHKxJwvxEGKMmobW0Qw/edit#gid=1416058780>

MySolution

- ❏ List of potential features to implement
- ❏

List of features in MySolution

- Simplified view of Solution data from MyPortfolio (related to IAM)
- Context Management
- Delegation Management
- Interface Contract Management
 - Replacing Super Context
 - Application 1 and Application 2 can together sign the interface contract defining the list of assets being shared between the two applications
- Smart Redirections along with analysis (with KPI's) from Solutions to IAM Assets:
 - Contexts / Sub Contexts
 - Roles
 - Groups
 - Accounts
-

MyIdentity

- ❑ List of potential features to implement
- ❑

List of features in MyIdentity

- Simplified view of identity (log on accounts) data from Air ID / Central IGA
- Merging below features to create an interactive view
 - Sparte feature (accounts synchronization to various environments)
 - Unix attributes from Anubis
 - Reset Password from MyPassword
- Smart Redirections along with analysis (with KPI's) from Identities to IAM Assets:
 - Roles
 - Groups
 - Accounts
- Redirections to Air ID / Onelogin / DSP / Data Checker etc., based on the end user needs
-

PAM

- ❏ List of potential features to implement
- ❏

Bastion Accounts

- Authorization for Bastion Accounts which needs Bastion Accounts to be integrated in MyAccess
-

Thank you

© Copyright Airbus 2023 / My IAM Architectural Proposal

This document and all information contained herein is the sole property of Airbus. No intellectual property rights are granted by the delivery of this document or the disclosure of its content. This document shall not be reproduced or disclosed to a third party without the expressed written consent of Airbus. This document and its content shall not be used for any purpose other than that for which it is supplied.

Airbus, its logo and product names are registered trademarks.